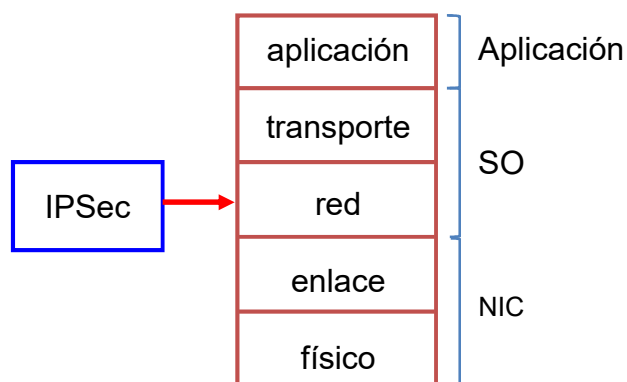


IPSec

IPSec: seguridad a nivel de red

- Protege paquetes IP entre dos hosts o puertas de enlace
Transparente para las aplicaciones

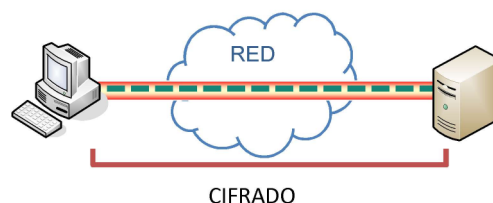


Protocolos de sesión IPSec: ESP y AH

- **Carga útil de seguridad encapsulada (ESP)**
 - Cifrado y/o autenticación (MAC) para cada paquete
 - Prevencción de repetición opcional con números de secuencia
 - Protege solo la carga útil IP (= PDU de capa de transporte)
 - *ESP con solo cifrado se considera inseguro*
- **Authentication Header (AH)**
 - Solo autenticación, sin cifrado
 - Autentica la carga útil IP y los campos inmutables del encabezado
 - *No recomendado.*

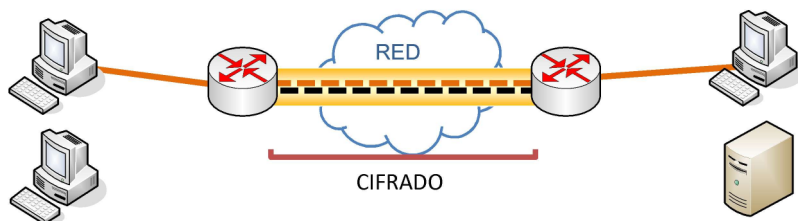
2 IPSec Modos de protocolo de sesión

- **Modo Transporte::**
 - **Seguridad Host-to-host.** Cifrado y/o autenticación de extremo a extremo
 - Cabecera ESP/AH añadida entre la cabecera IP original y los datos (payload)

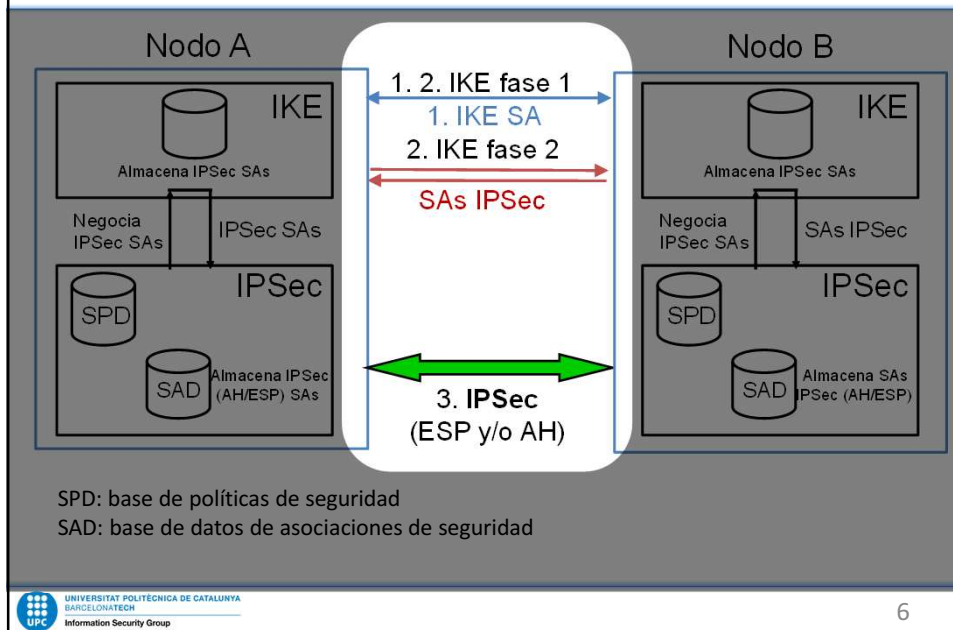


IPSec Modos de protocolo de sesión

- Modo Túnel (Cifrado y/o autenticación entre dos gateways (VPN)
 - Se utiliza habitualmente para crear túneles entre dos puertos de enlace para crear una VPN.
 - El paquete IP original se encapsula en una nueva cabecera IP más la cabecera ESP/AH



IPSec con IKE: Visión general



Intercambio de claves por Internet (IKE)

- Usado típicamente por IPSec para intercambio/acuerdo de claves
- Definido como un protocolo estándar; no solo para IPSec
- Diseño clásico en dos etapas o fases:
 - **Fase 1.** Handshake inicial protegido con certificados o claves precompartidas que acaban generando un acuerdo de un secreto maestro o IKE SA o ISAKMP SA
 - **Fase 2:** acuerdo protegido con la SA de IKE que crea las SA de AH o ESP; es decir, las claves de sesión requeridas para las sesiones actuales de IPSEC (AH o ESP)

Asociación de Seguridad (SA)

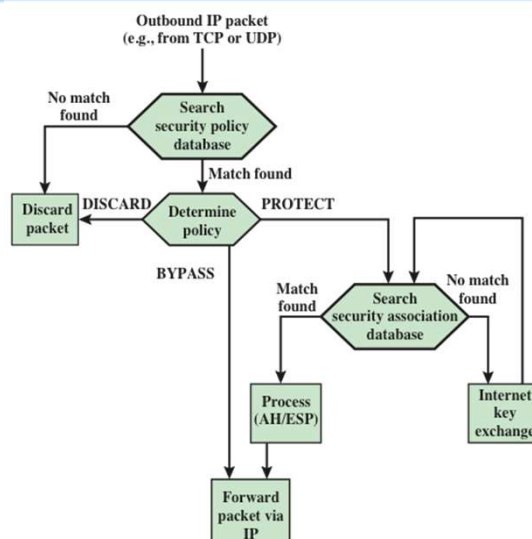
- Una forma de definir el contexto para el material criptográfico
- IPSec almacena las SAs en una base de datos SAD (SA Database)



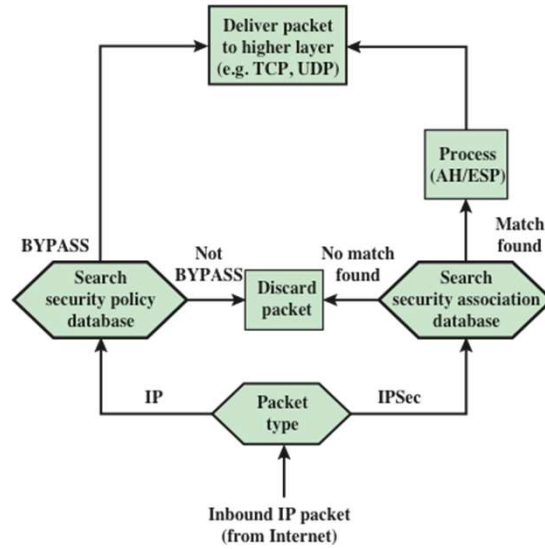
Base de datos de políticas de seguridad (SPD)

- La política asigna paquetes entrantes y salientes a acciones
- Selectores de políticas:
 - Dirección IP local y remota
 - Protocolo de transporte (TCP, UDP, ICMP)
 - Puertos de origen y destino
- Acciones: BYPASS (permitir), DISCARD (bloquear) o PROTECT (proteger)
 - PROTECT especifica también el protocolo de sesión y los algoritmos.
 - El paquete se asigna a una SA adecuada
 - Si la SA no existe, IKE se activa para crear una.
 - SPD almacena punteros a SA creadas previamente
- Las políticas de los nodos pares deben coincidir para poder comunicarse.

Paquetes salientes IPsec



Paquetes entrantes IPsec



Ejemplo de DOCUP de host

Protocol	Local IP	Port	Remote IP	Port	Action	Comment
UDP	1.2.3.101	500	*	500	BYPASS	IKE
ICMP	1.2.3.101	*	*	*	BYPASS	Error messages
*	1.2.3.101	*	1.2.3.0/24	*	PROTECT: ESP intransport-mode	Encrypt intranet traffic
TCP	1.2.3.101	*	1.2.4.10	80	PROTECT: ESP intransport-mode	Encrypt to server
TCP	1.2.3.101	*	1.2.4.10	443	BYPASS	TLS: avoid double encryption
*	1.2.3.101	*	1.2.4.0/24	*	DISCARD	Others in DMZ
*	1.2.3.101	*	*	*	BYPASS	Internet

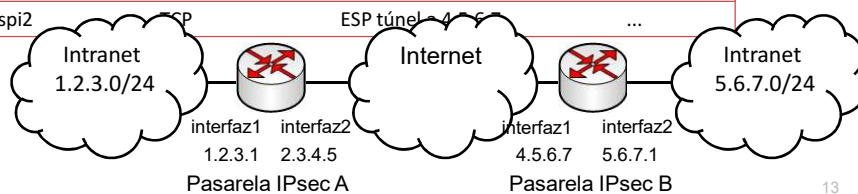
Ejemplo de SPD/SAD de pasarela

SPD de la pasarela A, interfaz 2

Protocolo	IP local	Puerto	IP remota	Puerto	Acción	Comentario
UDP	2.3.4.5	500	4.5.6.7	500	BYPASS	IKE
*	1.2.3.0/24	*	5.6.7.0/24	*	Túnel ESP a 4.5.6.7	Proteger el tráfico VPN
*	*	*	*	*	BYPASS	Todos los demás

SAD de la pasarela A

SPI	Selector SPD valores	Protocolo	Algoritmos, claves, estado del algoritmo
spi1	TCP, 1.2.3.0/24, 5.6.7.0/24	Túnel ESP desde 4.5.6.7	...
spi2	TCP	ESP túnel a 4.5.6.7	...



13

INTERCAMBIO DE CLAVES DE INTERNET (IKE)

14

IKEv1 Fase 1

- Cuatro opciones de "clave" diferentes
 - Cifrado de clave pública (versión original)
 - Cifrado de clave pública (versión mejorada)
 - Firma de clave pública
 - Clave simétrica
- Para cada una de ellas, dos "modos" diferentes
 - Modo principal
 - Modo agresivo
- **¡Hubo 8 versiones de IKE Fase 1!**

IKEv1 Fase 1

- Analizamos 6 de las 8 variantes de la Fase 1
 - Firmas de clave pública (modos principal y agresivo)
 - Clave simétrica (modos principal y agresivo)
 - Cifrado de clave pública (principal y agresivo)
- ¿Por qué cifrado de clave pública y firmas de clave pública?
 - Siempre se conoce la propia clave privada
 - Puede que (inicialmente) no conozca la clave pública de la otra parte

Modo principal

Se intercambian 6 mensajes y proporciona mayor seguridad, ya que oculta las identidades de los pares hasta que se establece el cifrado.

1. Negociación de parámetros de seguridad (SA)

Los peers intercambian propuestas de seguridad (algoritmos de cifrado, hash, método de autenticación, grupo DH).

Ejemplo: AES-256, SHA-512, DH Group 14, Pre-Shared Key.

2. Intercambio de claves Diffie-Hellman (DH)

Se generan claves temporales usando el grupo DH acordado.

Esto permite el **intercambio seguro de claves** sin transmitirlos directamente.

Modo principal

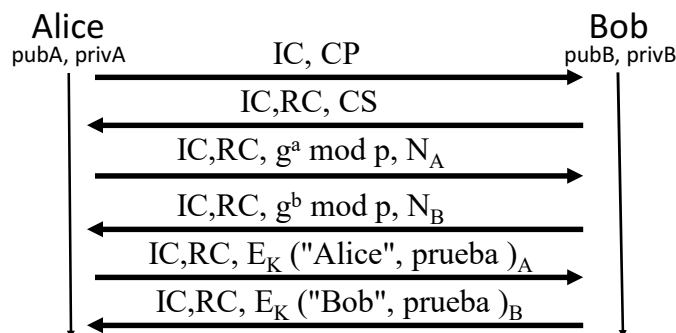
3. Autenticación

- Se verifica la identidad del peer usando:
 - **Claves precompartidas (PSK)**
 - **Certificados digitales (PKI)**
 - **Autenticación mediante clave pública (RSA, ECDSA)**
- Se intercambian hashes firmados para confirmar la autenticidad.

IKEv1 Fase 1

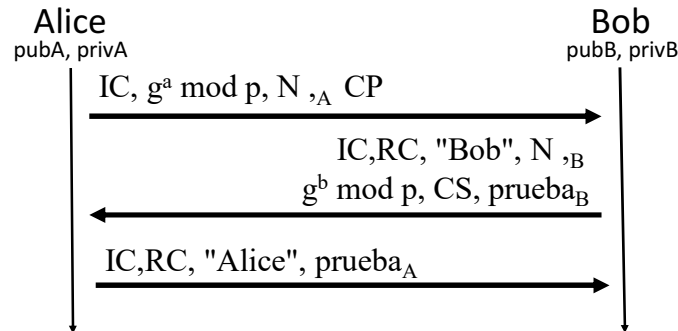
- Utiliza Diffie-Hellman efímero para establecer la clave de sesión
 - Proporciona secreto perfecto hacia adelante (PFS)
- Sea a el exponente Diffie-Hellman de Alice
- Sea b el exponente Diffie-Hellman de Bob
- Sea g un generador y p un primo
- Recordemos que p y g son públicos

IKEv1 Fase 1: Firma digital (Modo principal)



- CP = cripto propuesto, CS = cripto seleccionado
- IC = "cookie" iniciador, RC = "cookie" respondedor
- $K = h(IC, RC, g^{ab} \bmod p, N_A, N_B)$
- $SKEYID = h(N_A, N_B, g^{ab} \bmod p)$
- $prueba_A = S_{privA}(h(SKEYID, g^a \bmod p, g^b \bmod p, IC, RC, CP, "Alice"))$
- $prueba_B = S_{privB}(h(SKEYID, g^a \bmod p, g^b \bmod p, IC, RC, CP, "Bob"))$

IKEv1 Fase 1: Firma digital (Modo agresivo)

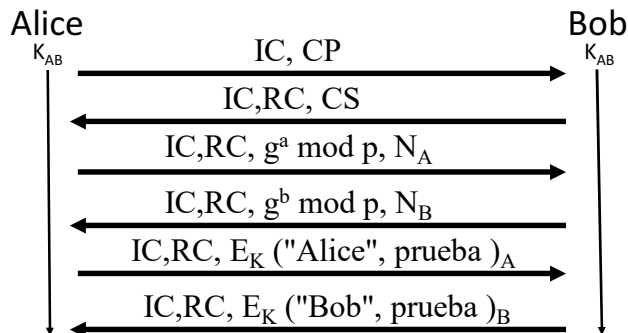


- Principal diferencia con el modo principal
 - No intenta proteger identidades

Modos principal y agresivo

- El modo principal DEBE aplicarse
- El modo agresivo DEBE aplicarse
 - En otras palabras, si no se implementa el modo agresivo, "debería sentirse culpable por ello"
- Podría crear problemas de interoperabilidad
- Para la autenticación de firma de clave pública
 - Un atacante pasivo conoce las identidades de Alice y Bob en modo agresivo.
 - El atacante activo puede determinar la identidad de Alice y Bob en modo principal

IKEv1 Fase 1: Clave simétrica (Modo principal)

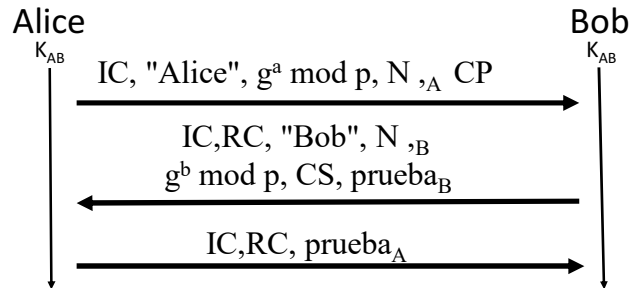


- K_{AB} = clave simétrica compartida de antemano
- $K = h(IC, RC, g^{ab} \bmod p, N_A, N_B, K)_{AB}$
- $SKEYID = h(K, g^{ab} \bmod p)$
- $_A \text{ prueba} = h(SKEYID, g^a \bmod p, g^b \bmod p, IC, RC, CP, "Alice")$
- $\text{prueba}_B = h(SKEYID, g^a \bmod p, g^b \bmod p, IC, RC, CP, "Bob")$

Problemas con la clave simétrica (modo principal)

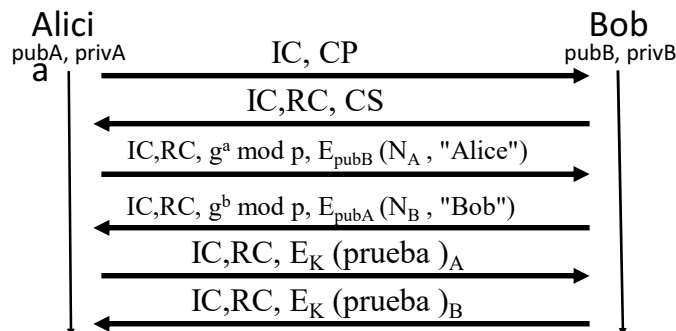
- Catch-22
 - Alice envía su ID en el mensaje 5
 - El ID de Alice encriptado con K
 - Para encontrar K Bob debe conocer K_{AB}
 - Para obtener K_{AB} Bob debe saber que está hablando con Alice!
- Resultado: **¡El ID de Alice debe ser la dirección IP!**
- ¿Por qué tomarse la molestia de intentar ocultar identidades en el protocolo de 6 mensajes?

IKEv1 Fase 1: SymmetricKey (Modo agresivo)



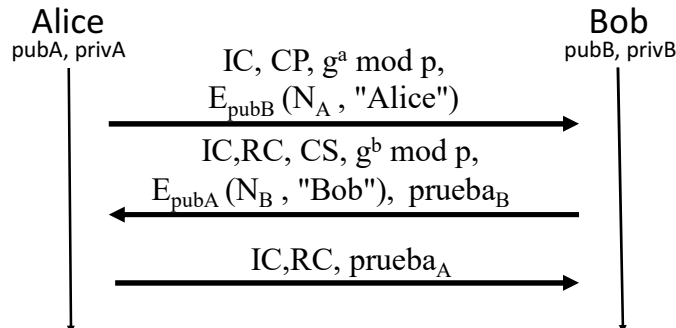
- Mismo formato que el modo agresivo de firma digital
- No intenta ocultar identidades...
- Como resultado, **no** tiene los problemas del modo principal
- Pero no (pretende) ocultar identidades

IKEv1 Fase 1: Cifrado de clave pública (modo principal)



- CP = cripto propuesto, CS = cripto seleccionado
- IC = "cookie" iniciador, RC = "cookie" respondedor
- $K = h(\text{IC}, \text{RC}, g^{ab} \bmod p, N_A, N_B)$
- $\text{SKEYID} = h(N_A, N_B, g^{ab} \bmod p)$
- $\text{prueba}_A = h(\text{SKEYID}, g^a \bmod p, g^b \bmod p, \text{IC}, \text{RC}, \text{CP}, \text{"Alice"})$
- $\text{prueba}_B = h(\text{SKEYID}, g^a \bmod p, g^b \bmod p, \text{IC}, \text{RC}, \text{CP}, \text{"Bob"})$

IKEv1 Fase 1: Cifrado de clave pública (modo agresivo)

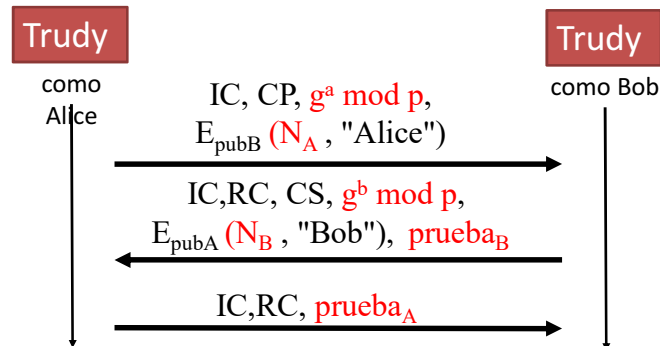


- $K, prueba_A, prueba_B$ calculada como en el modo principal
- Observe que las identidades están ocultas
 - El único modo agresivo que oculta identidades
 - Entonces, ¿por qué tener un modo principal?

¿Cuestión de cifrado de clave pública?

- Cifrado de clave pública, modo agresivo
- Supongamos **que Trudy** genera
 - Exponentes **a** y **b**
 - Nonces **N_A** y **N_B**
- Trudy puede calcular claves y pruebas "válidas":
 $g^{ab} \bmod p$, K , **SKEYID, **$prueba_A$** y **$prueba_B$****
- También es cierto para el modo principal

¿Cuestión de cifrado de clave pública?



- Trudy puede crear un intercambio que parece ser entre Alice y Bob.
- Parece válido para cualquier observador, **¡incluyendo Alice y Bob!**

Negación plausible

- Trudy puede crear una "conversación" que parezca ser entre Alice y Bob.
- Parece válida, ¡incluso para Alice y Bob!
- ¿Un **fallo de seguridad**?
- En este modo de IPSec, es una **característica**
 - **Negación plausible**: Alice y Bob pueden negar que haya habido conversación.
- En algunos casos puede crear un problema

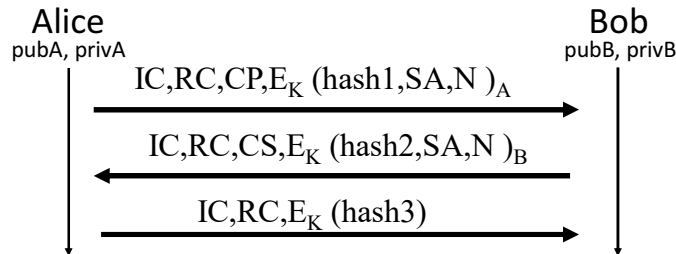
IKEv1 Fase 2

- Fase 1 establece IKE SA
- La fase 2 establece IPSec SA
- Comparación con TLS
 - La sesión TLS es comparable a IKE Fase 1
 - Las conexiones TLS son como IKE Fase 2
- IKE podría usarse para muchas cosas...
- ...pero en la práctica, ¡no!

IKEv1 Fase 2

- Pasos de la fase 2
- Negociación parámetros IPSEC
 - Las partes intercambian propuestas para: cifrado (algoritmo), autenticación, protocolo (ESP o AH) y modo (túnel o transporte)
- Perfect Forward Secrecy (PFS - Opcional):
 - Si se negocia, se realiza un nuevo intercambio Diffie-Hellman (DH) para generar claves efímeras, independientes de las de la Fase 1. Aumenta la seguridad: incluso si la clave de la Fase 1 es comprometida, las claves de la Fase 2 siguen protegidas.
- Generación de claves para IPsec:
 - Las claves se derivan del material de la Fase 1 + nonces (números aleatorios) de la Fase 2.
- Establecimiento de Security Associations (SA):
 - Se crean dos SA unidireccionales (entrante/saliente) con: SPI (Security Parameter Index): Identificador único de cada SA; tiempo de vida (lifetime): Duración antes de renegociar (ej: 1 hora o 1 GB de datos).
- Intercambio de hashes (HMAC):
 - Ambos lados verifican la integridad del proceso con hashes firmados.

IKEv1 Fase 2



- Clave K, IC, RC y SA conocidas de la Fase 1
- La propuesta CP incluye ESP y/o AH
- Hashes 1,2,3 dependen de SKEYID, SA, N_A y N_B
- Claves derivadas de $KEYMAT = h(\text{SKEYID}, N_A, N_B, \text{junk})$
- Recordemos que SKEYID depende del método de clave de la fase 1
- PFS opcional (intercambio efímero Diffie-Hellman)

IKE versión 2

- [RFC 4306](#) y [RFC 7296](#)
- simplifica los flujos de intercambio de claves y soluciona las ambigüedades y vulnerabilidades inherentes a IKEv1
- Resuelve el número excesivo de casos (a menudo inútiles) de IKEv1
- Y añade más funcionalidades

IKEv2: mejoras con respecto a IKEv1

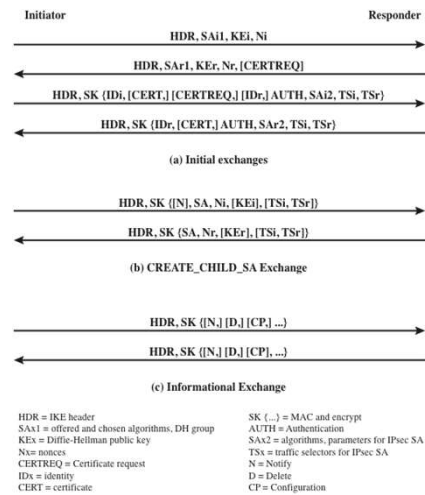
- IKEv2 admite más algoritmos de cifrado, incluida la autenticación asimétrica
- IKEv2 es más estable gracias a su compatibilidad con el protocolo de movilidad y multihoming (MOBIKE)
- IKEv2 utiliza menos datos de ancho de banda al emplear un número reducido de asociaciones de seguridad necesarias
- IKEv2 incorpora NAT traversal, lo que le permite atravesar cortafuegos.
- IKEv2 puede determinar si un túnel está activo, gracias a su función "mantener vivo", que siempre está activada.
- IKEv2 es compatible con una técnica de autenticación llamada Protocolo de Autenticación Extensible (EAP) que protege la comunicación.
- IKEv2 es altamente fiable, gracias a su secuencia de números y acuses de recibo mejorados.
- IKEv2 es más resistente a los ataques DoS gracias a su capacidad para comprobar y determinar si existe un solicitante antes de realizar cualquier acción.

IKEv2: Asociaciones de Seguridad (SAs)

- IKEv2 se utiliza para gestionar/acordar dos tipos de SA
 1. IKE_SA
 - Acordada durante los intercambios iniciales (handshake)
 2. CHILD_SA
 - Asociación de seguridad por servicio
 - En el caso de IPSec (que es casi siempre el caso), una CHILD_SA será ESP o AH

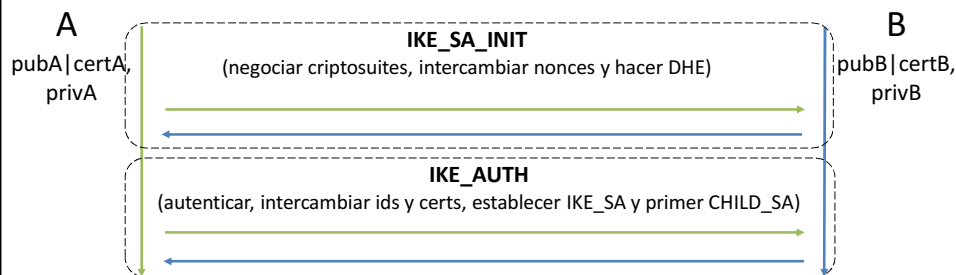
Los cuatro intercambios de IKEv2

- Todas las comunicaciones IKEv2 consisten en pares de mensajes (petición-respuesta) llamados **intercambios**:
 - Intercambios iniciales: IKE_SA_INIT e IKE_AUTH
 - CREATE_CHILD_SA
 - INFORMATIVO



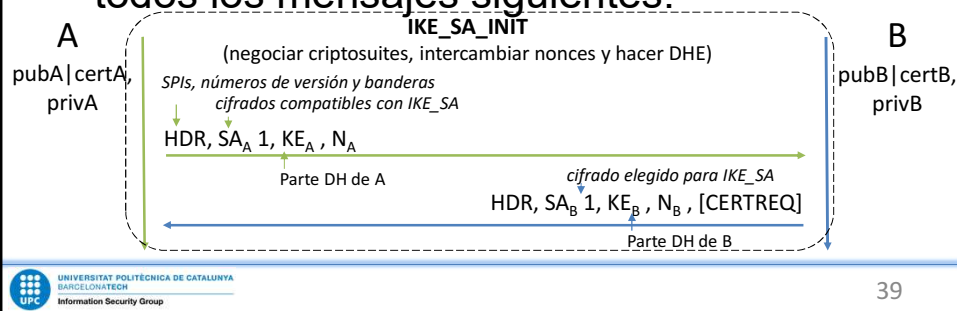
IKEv2: Intercambios iniciales (1/3)

- La comunicación usando IKE siempre comienza con IKE_SA_INIT e IKE_AUTH
 - conocido en IKEv1 como Fase 1



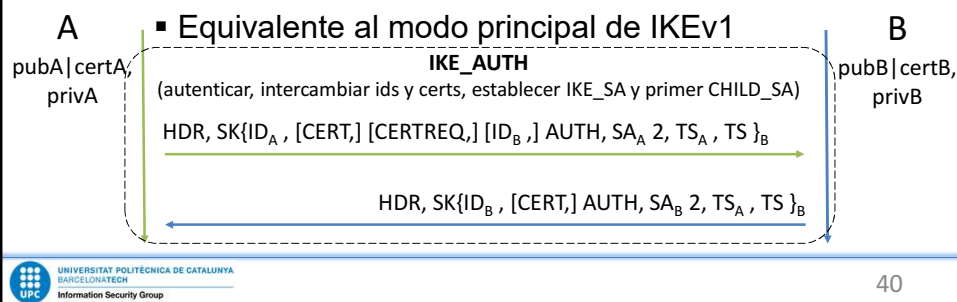
IKEv2: Intercambios iniciales (2/3): IKE_SA_INIT

- Negociar criptosuites, intercambiar nonces, y hacer DHE
- A partir del secreto acordado cada parte obtiene claves de cifrado y autenticación en ambas direcciones, para proteger todos los mensajes siguientes.



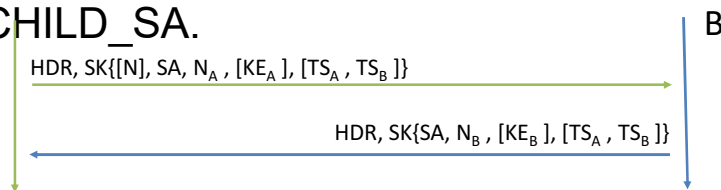
IKEv2: Intercambios iniciales (3/3): IKE_AUTH

- Las claves previamente acordadas se utilizan para proteger la autenticación y establecer IKE_SA y primer CHILD_SA.
 - SK{} significa cifrado y autenticado.
 - Los ID y certificados están "ocultos" (se intercambian cifrados).



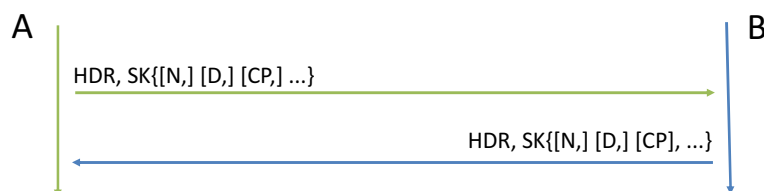
IKEv2: Intercambio CREATE_CHILD_SA

- Anterior IKEv1 fase 2
- Protegido con el IKE_SA
- Aunque el primer CHILD_SA (y a menudo el único necesario) se obtiene tras los intercambios iniciales, puede ser necesaria la creación posterior de CHILD_SA.



IKEv2: Intercambio de información

- Intercambios informativos para: eliminar un SA, informar de condiciones de error, comprobar la vivacidad (con carga útil cifrada vacía).
- Protegido con IKE_SA



AH/ESP

IPSec

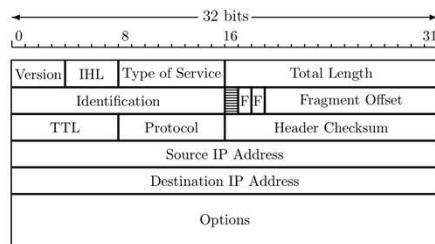
- Después de IKE Fase 1, tenemos un IKE SA
- Después de IKE Fase 2, tenemos un IPSec SA
- Ambas partes han compartido claves simétricas
- ¿Y ahora qué?
 - Queremos proteger los datagramas IP
- Pero, ¿qué es un datagrama IP?
 - Desde la perspectiva de IPSec...

Revisión de IP

- El datagrama IP es de la forma

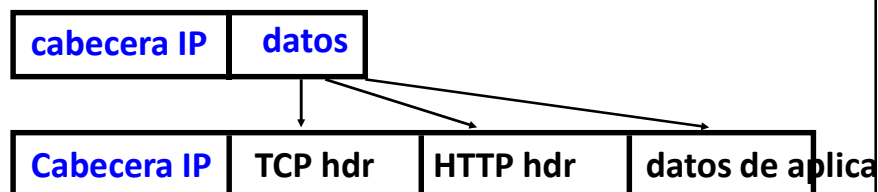


- Donde la cabecera IP es



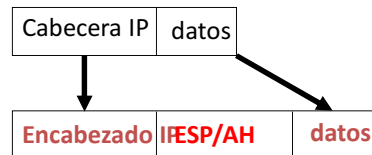
IP y TCP

- Considere el tráfico HTTP (sobre TCP)
 - IP encapsula TCP y...
 - ...TCP encapsula HTTP



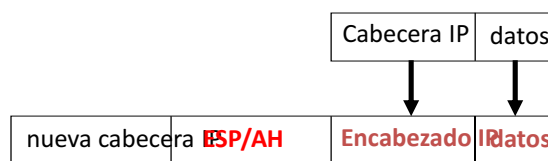
- Los datos IP incluyen la cabecera TCP, etc.

Modo de transporte IPsec



- Modo de transporte diseñado para host-to-host
 - El modo de transporte es eficiente
- Añade una cantidad mínima de cabecera adicional
 - La cabecera original permanece
- El atacante pasivo puede ver quién está hablando

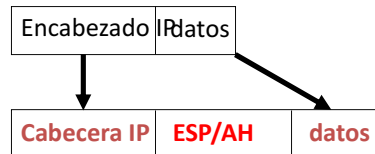
Modo túnel IPsec



- Modo túnel para tráfico **de cortafuegos a cortafuegos**
- Paquete IP original encapsulado en IPsec
- Cabecera IP original no visible para el atacante
- Nueva cabecera IP de cortafuegos a cortafuegos
- El atacante no sabe qué hosts están hablando

Comparación de los modos IPSec

- Modo transporte



- Modo túnel



- Modo transporte

- De host a host

- Modo túnel

- Cortafuegos a cortafuegos

- El modo de transporte no es necesario

- El modo de transporte es más eficaz

Seguridad IPSec

- ¿Qué tipo de protección?
 - ¿Confidencialidad?
 - ¿Integridad?
 - ¿Ambas?
- ¿Qué proteger?
 - ¿Los datos?
 - ¿Cabecera?
 - ¿Ambos?
- ESP/AH hacen algunas combinaciones de estos

AH frente a ESP

- AH --- Cabecera de autenticación
 - **Sólo integridad** (sin confidencialidad)
 - Integridad-protege todo más allá de la cabecera IP y algunos campos de la cabecera (¿por qué no todos los campos?)
- ESP --- Carga útil de seguridad encapsulada
 - **Integridad y confidencialidad requeridas**
 - Protege todo más allá de la cabecera IP
 - **Integridad-sólo** mediante [cifrado NULL](#)

Cifrado NULL de ESP

- Según el RFC 2410
 - El cifrado NULL "es un cifrado por bloques cuyos orígenes parecen perderse en la antigüedad"
 - "A pesar de los rumores", no hay pruebas de que la NSA "suprimiera la publicación de este algoritmo"
 - Las pruebas sugieren que se desarrolló en la época romana como versión exportable del cifrado de César
 - Puede hacer uso de claves de longitud variable
 - No requiere IV
 - $\text{Null}(P,K) = P$ para cualquier P y cualquier clave K
- Conclusión: La gente de seguridad es extraña...

¿Por qué existe AH? (1/3)

- No puede cifrar la cabecera IP
 - Los routers deben mirar la cabecera IP
 - Direcciones IP, TTL, etc.
 - La cabecera IP existe para enrutar paquetes.
- AH protege **los campos inmutables** de la cabecera IP
 - No puede proteger la integridad de todos los campos de la cabecera
 - TTL, por ejemplo, debe cambiar
- ESP no protege la cabecera IP en absoluto
- Sin embargo, la protección de la cabecera IP es incompatible con el enmascaramiento.

¿Por qué existe AH? (2/3)

- La cuestión es... ¿cuál es el valor añadido de proteger la cabecera IP?
- ESP encripta todo más allá de la cabecera IP (si la encriptación no es nula)
- Si ESP está encriptado, el cortafuegos no puede mirar la cabecera TCP (por ejemplo, números de puerto)
- ¿Por qué no utilizar ESP con cifrado NULL?
 - El cortafuegos ve la cabecera ESP, pero no sabe si se utiliza cifrado nulo
 - Los sistemas finales lo saben, pero no los cortafuegos

¿Por qué existe AH? (3/3)

- La verdadera razón de la existencia de AH:
 - En una reunión del IETF "alguien de Microsoft pronunció un apasionado discurso sobre la inutilidad de AH...".
 - "...todos en la sala miraron a su alrededor y dijeron `Hmm. Tiene razón, y nosotros también odiamos AH, pero si molesta a Microsoft dejémoslo, ya que odiamos a Microsoft más que a AH".
- **Hoy en día AH se considera un protocolo antiguo y no se recomienda**